

Risk ID	Asset Name	Threat Summary	Risk Level	Security Control
R-001	Customer PII Records	Data breach via unauthorized access or insider threat	Critical	Encrypt all PII data at rest (AES-256) and in transit (TLS 1.2+); enforce Role-Based Access Control (RBAC)
R-001	Customer PII Records	Data breach via unauthorized access or insider threat		Conduct quarterly access reviews — remove or adjust permissions for users who no longer need them
R-002	Payment Gateway (Stripe)	Magecart skimming attack captures live card data	High	Implement Content Security Policy (CSP) headers to block unauthorized scripts; monitor third-party script integrity
R-002	Payment Gateway (Stripe)	Magecart skimming attack captures live card data		Maintain PCI-DSS compliance — conduct annual SAQ (Self-Assessment Questionnaire) with payment processor
R-003	E-Commerce Web Application	SQL injection exploits app vulnerability to extract database	Critical	Deploy Web Application Firewall (WAF); enforce input validation and parameterized queries in all app code
R-004	E-Commerce Web Application	DDoS attack causes extended downtime and lost revenue	High	Enable AWS Shield (DDoS protection); implement rate limiting and traffic filtering at network edge

Risk ID	Asset Name	Threat Summary	Risk Level	Security Control
R-005	Admin / Privileged Accounts	Privilege abuse by disgruntled employee	High	Enforce least privilege — audit all admin accounts quarterly; immediately disable accounts upon termination
R-006	Admin / Privileged Accounts	Credential compromise via phishing gives attacker admin access	Critical	Enforce Multi-Factor Authentication (MFA) on all privileged accounts without exception
R-006	Admin / Privileged Accounts	Credential compromise via phishing gives attacker admin access	Critical	Conduct quarterly phishing awareness training; run simulated phishing campaigns to measure click rates
R-007	Cloud Hosting (AWS)	Misconfigured S3 bucket exposes sensitive data publicly	Medium	Implement Cloud Security Posture Management (CSPM); enforce S3 bucket policies blocking all public access by default
R-008	Business Email System	BEC attack impersonates executive for fraudulent wire transfer	Medium	Implement DMARC, DKIM, and SPF email authentication to block domain spoofing
R-008	Business Email System	BEC attack impersonates executive for fraudulent wire transfer	Medium	Establish verbal verification policy — all wire transfers above \$500 require a phone call to confirm

Risk ID	Asset Name	Threat Summary	Risk Level	Security Control
R-009	Backup System	Ransomware encrypts primary and backup systems	Medium	Maintain offline/air-gapped backups stored separately from primary network; test restoration quarterly
R-010	Network Router / Firewall	Firewall misconfiguration exposes internal network ports		Conduct bi-annual firewall rule audits; implement network segmentation to isolate critical systems

NIST CSF Function	Control Type	Implementation Priority	Success Metric	Notes
PROTECT	Preventive	P1 — Immediate	100% of PII fields encrypted; access logs reviewed monthly; zero unauthorized access incidents	Encryption is the last line of defense if perimeter controls fail. RBAC ensures only authorized roles access PII.
GOVERN	Preventive		Access review completed every 90 days; zero orphaned accounts with active PII access	Access creep is a leading cause of insider breaches. Regular reviews enforce least privilege over time.
PROTECT	Preventive		CSP headers active on all payment pages; zero unauthorized scripts detected in monthly scans	Magecart attacks inject scripts via third-party libraries. CSP prevents unauthorized scripts from executing.
GOVERN	Preventive		Annual PCI-DSS SAQ completed; zero compliance violations flagged by payment processor	PCI-DSS compliance is legally required for card processing. Non-compliance risks payment processing revocation.
PROTECT	Preventive	P1 — Immediate	WAF active and updated monthly; zero SQL injection vulnerabilities in quarterly penetration test	SQL injection remains the #1 web application attack vector. WAF + input validation eliminates most attack surface.
PROTECT	Preventive	P2 — Short-Term	AWS Shield active; rate limiting configured; maximum acceptable downtime under 15 minutes per incident	Cloud-native DDoS protection is cost-effective for small companies. Rate limiting stops volumetric attacks.

NIST CSF Function	Control Type	Implementation Priority	Success Metric	Notes
PROTECT	Preventive	P1 — Immediate	100% of terminated employee accounts disabled within 1 hour of offboarding; quarterly privilege audit completed	Orphaned accounts are a critical insider threat vector. Same-day offboarding is a non-negotiable control.
	Preventive		MFA enabled on 100% of admin accounts; zero privileged account logins without MFA in audit logs	MFA is the single most effective control against credential-based attacks. Eliminates password-only access.
	Preventive		Phishing simulation click rate below 5%; 100% of staff complete annual security awareness training	Human error drives 90%+ of breaches. Training reduces susceptibility and builds security culture.
DETECT	Detective	P3 — Medium-Term	CSPM scans run weekly; zero publicly accessible S3 buckets containing sensitive data	Misconfiguration is the #1 cloud breach cause. Automated CSPM catches drift before attackers do.
PROTECT	Preventive	P1 — Immediate	DMARC policy set to reject; zero spoofed emails from company domain reaching inboxes	DMARC/DKIM/SPF prevent attackers from sending emails that appear to come from your domain.
GOVERN	Preventive	P1 — Immediate	100% of wire transfers above threshold verified by phone; zero unauthorized transfers executed	BEC succeeds through urgency and authority. A simple phone call policy eliminates most BEC financial losses.

NIST CSF Function	Control Type	Implementation Priority	Success Metric	Notes
RECOVER	Responsive	P3 — Medium-Term	Backup restoration test completed quarterly; recovery time objective (RTO) under 4 hours	Air-gapped backups are immune to ransomware. Untested backups are not backups — test quarterly without exception.
DETECT	Detective		Firewall audit completed every 6 months; zero unnecessary open ports on internal network	Firewall rules accumulate over time. Regular audits remove outdated rules that create unintended exposure.